

Short intro to Entra Agent Id

Marius Rochon

OWASP Agentic Threat	How Entra Agent ID Helps	Specific Agent ID / Entra Features	Coverage Assessment
1. Prompt Injection	Does not prevent injection , but can limit blast radius if an agent is successfully manipulated.	- Per-agent identity isolation (Agent ID) - Permission scoping via Graph / APIs - CA-enforced token restrictions	 Partial Identity limits <i>impact</i> , not <i>entry</i> . Prompt injection must be handled at app / model layer.
2. Tool Misuse / Over-permissioned Agents	Strong mitigation by enforcing least privilege at identity level .	- Agent-specific identities (no shared app IDs) - OAuth scopes / app roles per Agent ID - Ability to disable or block Agent ID	 Strong One of the best-covered threats by Agent ID.
3. Unauthorized Delegation / Acting as the Wrong User	Prevents silent impersonation; enables explicit, auditable delegation only via <code>agentUser</code> .	<code>agentUser</code> object as explicit delegate - CA evaluated for agent + delegate - Graph permissions enforced	 Strong Direct mitigation of unauthorized “Act-As” behavior.
4. Excessive Agent Autonomy	Limits what an agent <i>can do</i> , not <i>how often</i> it does it.	- Token lifetime enforcement - CA session restrictions - Ability to revoke tokens by disabling Agent ID	 Partial Autonomy control is mainly an application orchestration concern.
5. Data Exfiltration via APIs	Reduces reachable data surfaces and enables network-based blocking .	- CA Named Locations - Resource-specific access tokens - Agent-scoped API permissions	 Moderate Effective for <i>API-based</i> exfiltration, not model responses.
6. Cross-Agent Lateral Movement	Strongly prevents lateral movement by default isolation .	- One Agent ID per copilot - No shared credentials - Independent CA targeting	 Strong Identity isolation is the primary defense.
7. Credential Theft / Token Replay	Mitigates long-lived or reusable credentials.	- Short-lived client-credentials tokens - CA evaluation at token issuance - Sign-in logs for agents	 Strong Comparable to mature workload identity security.
8. Agent Supply-Chain Attacks (malicious plugins)	Does not detect malicious logic , but prevents it from inheriting broad trust implicitly.	- No automatic trust between agents - Explicit consent required for permissions	 Partial Supply-chain validation is outside identity scope.
9. Insufficient Agent Accountability / Logging Gaps	Strongly improves attribution and auditability.	- Agent-specific sign-in logs - CA + Entra audit logs - Distinct principal per agent	 Strong Major improvement over shared app identities.
10. Human Trust Abuse (	No direct mitigation . Identity does not influence user trust decisions.	None (identity layer only)	 Not mitigated This is a UX, policy, and training problem.

Artifacts

- Entra objects
 - agentIdentityBlueprint
 - agentIdentity
 - agentUser
- OAuth2 flows
 - New parameters on Client Creds
 - New token claim
- Conditional Access
 - Target specific agents or collections of agents
 - Use agent security attributes
 - Non-human interactions
- Portals
 - Entra
 - M365 Admin
- APIs/SDKs
 - MS Graph
 - Agent365 SDK/CLI
 - Entra SDK for Agent ID

agentIdentityBlueprint

- Extension of *Application* and *Service Principal* objects:
 - inheritablePermissions/inheritableScopes
 - sponsors/owners
- Container of permission definitions and security attributes
- Provisioned automatically: Foundry for each project, CopilotStudio - one for the tenant
- ...or, via Agent365 SDK/CLI or MS Graph
- Provisions agent instances with identities and runtime privileges
- Show shape

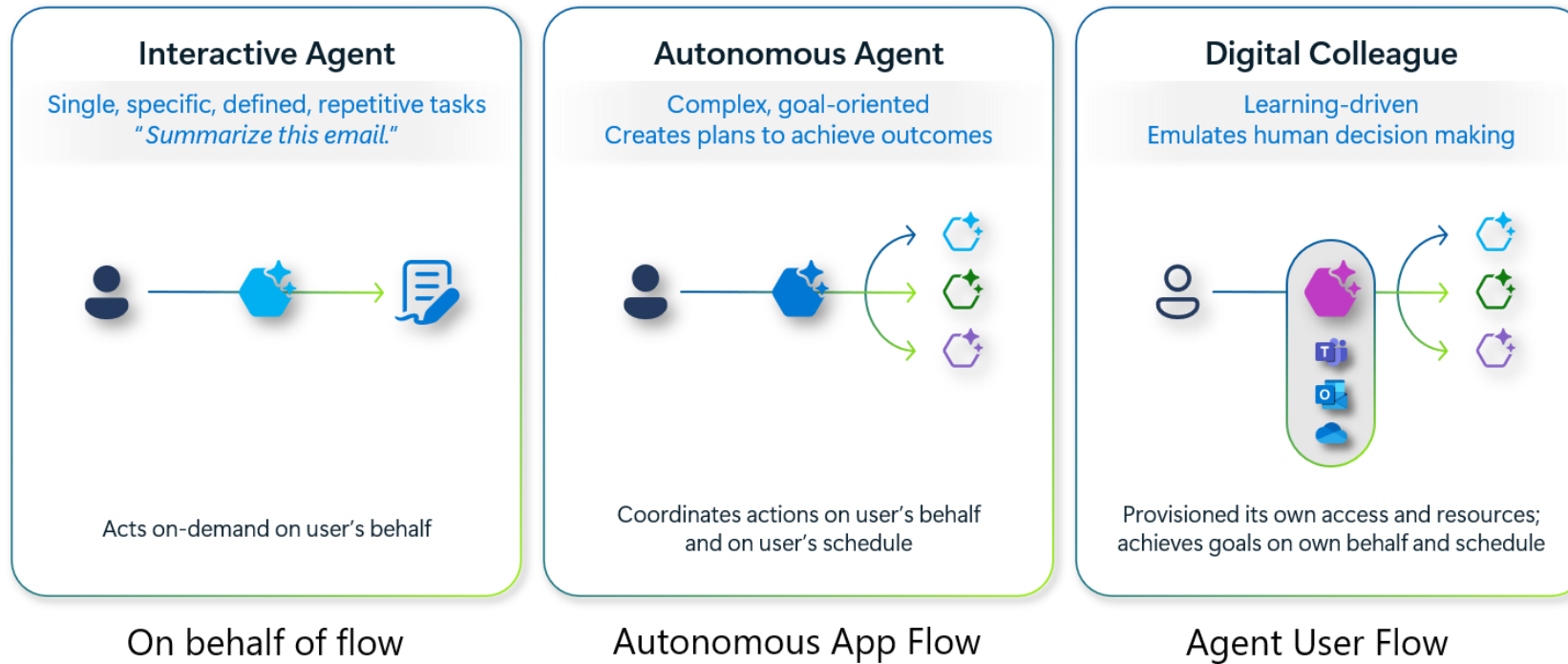
agentIdentity

- Extension of *ServicePrincipal* – similar to multi-tenant apps
- A blueprint may define any number of agentIdentities
- Blueprint defines max permissions envelope
- Credentials managed by blueprint
- Analogy:
 - Blueprint – host
 - Entra – receptionist
 - AgentId – visitor

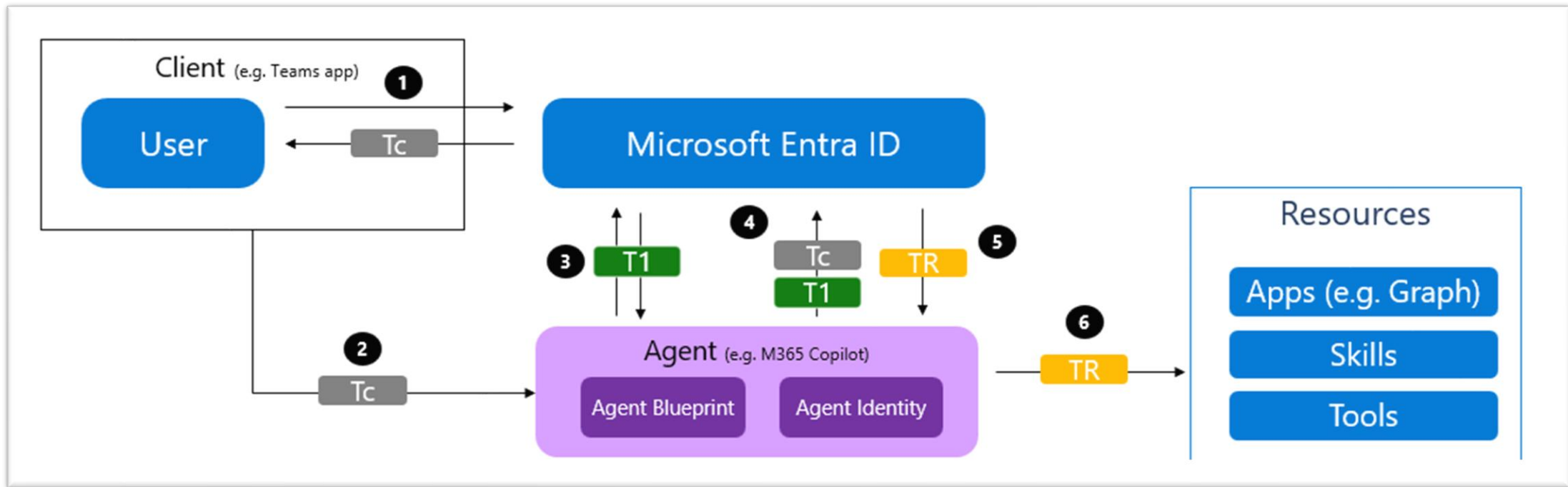
agentUser

- Extension of *user* object
- Credentialed by blueprint and agentIdentity
- Use for scenarios where agent needs to be like a human user, e.g. mailbox delegate, i.e. does not require human presence
- Serves different scenarios than OBO (requires a human)
- Took four conversation turns to correct Copilot's hallucinations!
 - "There is no object called agentUser"
 - "agentUser does not use tokens"
- Analog: AgentIdentity 'puppet'

Entra Agent ID Scenarios



OBO agent



Demo

- [Agent Identity Token Tester](#)

Resources

- <https://github.com/microsoft/Agent365-samples>
- <https://github.com/microsoft/entra-agentid-samples>
- <https://github.com/mrochon/AgentIDSamples> shows:
 - Graph creating blueprints/agentids
 - Host executing token acquisitions